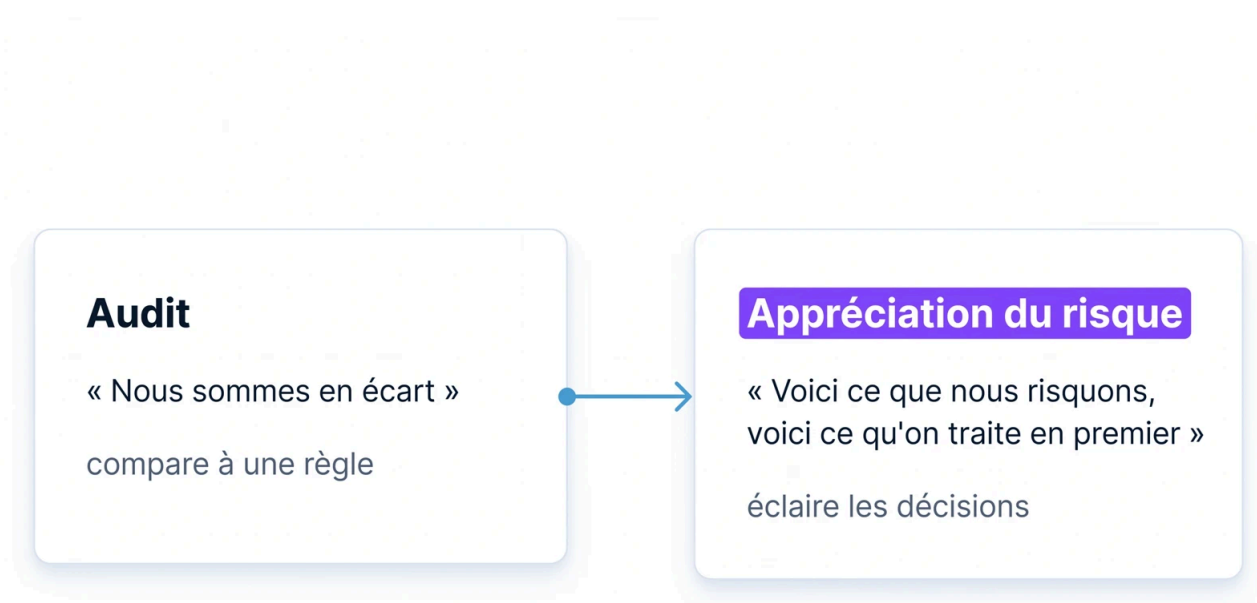


Concepts du risque et méthode EBIOS Risk Manager

De l'audit au risque : pourquoi mesurer l'écart ne suffit pas



Objectifs de la séance

À l'issue de ce cours :

- **Définir** le vocabulaire du risque : risque, gravité, vraisemblance, niveau de risque, événement redouté, source de risque, objectif visé
- **Situer** ISO/IEC 27005:2022 et ISO 31000:2018 dans le paysage normatif, et expliquer ce qui les distingue d'ISO/IEC 27001:2022

- **Présenter** la méthode EBIOS Risk Manager : ce qu'elle est, d'où elle vient, comment ses cinq ateliers s'enchaînent, et ce qu'elle ne fait pas
- **Expliquer** la complémentarité entre approche par conformité et approche par scénarios, et savoir laquelle mobiliser pour quel type de menace
- **Préparer** les ateliers 1 et 2 à conduire cet après-midi sur le groupe MERIDIAN

Prérequis

- La cartographie de la séance 2 : les valeurs métier et les biens supports du groupe MERIDIAN y sont déjà identifiés, et ce cours explique pourquoi c'était la vraie première étape de l'analyse de risque.
- Le rapport d'audit de la séance 4 et ses écarts qualifiés : ils vont alimenter directement le socle de sécurité.
- L'appétence au risque, travaillée ce matin : c'est elle que l'appréciation du risque viendra confronter au réel.

La question que l'audit laisse ouverte

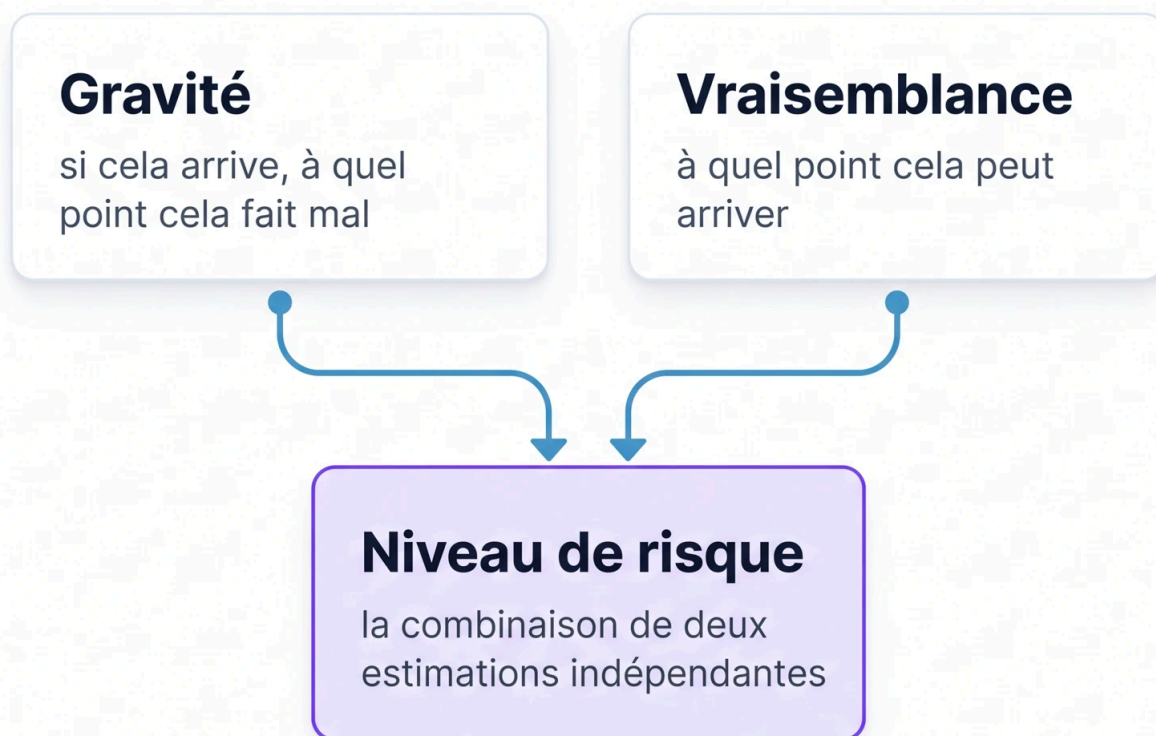
La séance 4 s'est conclue sur un rapport d'audit : une liste d'écarts entre ce que le référentiel exige et ce que le groupe fait. C'est une photographie honnête, mais elle ne répond pas à la question que la direction se pose vraiment : parmi ces écarts, lesquels peuvent faire mal, à quel point, et par la main de qui ? Un audit compare à une règle ; il ne dit pas ce qu'un attaquant motivé ferait de chaque manquement, ni ce qu'une indisponibilité coûterait à la filiale Santé un jour de garde. Pour passer de « nous sommes en écart » à « voici ce que nous risquons et voici ce qu'on traite en premier », il faut une autre discipline : l'appréciation du risque. Ce cours en donne le vocabulaire, les textes de référence, puis la méthode appliquée tout l'après-midi.

✓ Le vocabulaire : six mots qui portent tout l'édifice

D'abord, le mot central. Le glossaire du guide EBIOS Risk Manager définit le **risque** ainsi : « Possibilité qu'un événement redouté survienne et que ses effets impactent les missions de l'objet de l'étude. » Chaque mot travaille. « Possibilité » : un risque n'est pas un fait, c'est un futur plausible ; il se manipule donc avec des estimations, jamais avec des certitudes. « Événement redouté » : le risque part de ce que l'organisation craint pour ce qui compte, pas d'une liste de techniques d'attaque. « Missions » : la mesure finale du risque est métier, pas informatique. Une base de données chiffrée qui tombe sans conséquence sur aucune mission ne porte presque pas de risque ; un partage de fichiers anodin qui conditionne les admissions d'un hôpital en porte beaucoup.

Un risque s'estime alors selon deux dimensions indépendantes. La **gravité** : « Estimation du niveau et de l'intensité des effets d'un risque », dit le glossaire. Elle répond à « si cela arrive, à quel point cela fait mal ». La **vraisemblance** : « Estimation de la faisabilité ou de la probabilité qu'un risque se réalise, selon l'échelle adoptée. » Elle répond à « à quel point cela peut arriver ». Et leur combinaison donne le **niveau de risque** : « Mesure de l'importance du

risque, exprimée par la combinaison de la gravité et de la vraisemblance. » À retenir : ces deux dimensions ne se compensent pas moralement : un événement catastrophique mais très difficile à réaliser et un incident bénin mais quotidien peuvent finir au même niveau de risque, et appeler pourtant des traitements très différents. La grille combine, le jugement arbitre.



Trois acteurs peuplent ensuite ce vocabulaire. L'**événement redouté** est défini par le glossaire comme associé à une valeur métier : il « porte atteinte à un critère ou besoin de sécurité de la valeur métier », et « chaque événement redouté est estimé selon le niveau de gravité des conséquences, à partir d'une métrique ». Les briques de la séance 2 se reconnaissent ici : les valeurs métier et les biens supports, définis lors de la cartographie, se réutilisent tels quels, et les besoins de sécurité DICT (disponibilité, intégrité, confidentialité, traçabilité) déjà cotés servent de guide pour formuler ce qu'on redoute : une atteinte à la disponibilité, à l'intégrité, à la confidentialité ou à la traçabilité de chaque valeur métier.

La **source de risque**, elle, désigne « élément, personne, groupe de personnes ou organisation susceptible d'engendrer un risque », caractérisable « par sa motivation, ses ressources, ses compétences, ses modes opératoires ». Et l'**objectif visé** est la « finalité visée par une source de risque, selon ses motivations ». La distinction entre les deux derniers est plus fine qu'il n'y paraît : l'objectif visé est ce que l'attaquant veut obtenir (voler un savoir-faire, extorquer une rançon), la motivation est ce qui l'y pousse (l'appât du gain, l'idéologie, la

vengeance). Le guide met explicitement en garde contre leur confusion, et le QCM de ce midi ne la pardonnera pas non plus.

Terme	La question à laquelle il répond	Exemple MERIDIAN
Valeur métier (séance 2)	Qu'est-ce qui compte pour la mission ?	La gestion des dossiers patients de la filiale Santé
Bien support (séance 2)	Sur quoi cela repose-t-il ?	Le SGBD (système de gestion de base de données) de données de santé
Événement redouté	Que craint-on pour cette valeur métier ?	La divulgation de dossiers patients
Source de risque	Qui ou quoi pourrait le provoquer ?	Un groupe cybercriminel
Objectif visé	Pour obtenir quoi ?	Extorquer une rançon au groupe
Niveau de risque	Quelle importance, tout compte fait ?	Combinaison de la gravité et de la vraisemblance

Ce tableau se lit de haut en bas, et cet ordre n'est pas décoratif : c'est celui de la méthode à appliquer. On part de ce qui compte, on formule ce qu'on craint, on cherche qui pourrait le provoquer, et on finit par mesurer. Un raisonnement qui commence par « quelles sont les vulnérabilités de nos serveurs » prend le problème à l'envers : produira un inventaire technique sans jamais dire à la direction ce qui menace les missions.

✓ Les textes : ce qui exige, ce qui guide, ce qui outille

Trois références se partagent le terrain, et les confondre est l'erreur la plus répandue du domaine. La bibliographie du guide EBIOS Risk Manager les cite dans ces termes exacts : « ISO 31000:2018, Management du risque, Principes et lignes directrices », « ISO 27001:2022, Systèmes de management de la sécurité de l'information, Exigences », et ISO 27005:2022, Préconisation pour la gestion des risques liés à la sécurité de l'information ».

Les titres disent presque tout. **ISO 31000:2018** traite du management du risque en général : financier, industriel, juridique, numérique, tout risque d'organisation. C'est le socle conceptuel commun, celui dont le vocabulaire d'appréciation du module descend. **ISO/IEC 27001:2022** s'intitule « Exigences » : c'est la norme de la séance 3, celle contre laquelle on se fait certifier, et elle exige notamment que l'organisme apprécie et traite ses risques de sécurité de l'information. Mais exiger n'est pas expliquer comment faire. **ISO/IEC 27005:2022**, quatrième édition publiée en octobre 2022, est précisément ce mode d'emploi : une préconisation, pas une norme d'exigences ; on ne se certifie pas ISO 27005, on s'en inspire pour construire son processus de gestion du risque. La séance 7 déroulera

ce processus normalisé de bout en bout, de l'établissement du contexte jusqu'au traitement et à la surveillance ; aujourd'hui, il suffit de savoir où la norme se place et ce qu'elle n'est pas.

Reste la question que tout étudiant se pose à ce stade : si les normes internationales couvrent le sujet, pourquoi une méthode française ? Voici la fiche d'identité.

Fiche notion : EBIOS Risk Manager

Le problème auquel elle répond : une organisation qui veut apprécier ses risques numériques se retrouve devant des textes normatifs qui décrivent QUOI faire sans détailler COMMENT s'y prendre, avec qui autour de la table, dans quel ordre et avec quels livrables. La méthode comble exactement ce vide. Ce qu'elle est, selon l'avant-propos du guide : « EBIOS Risk Manager (EBIOS RM) est la méthode d'appréciation et de traitement du risque numérique publiée par l'Agence nationale de la sécurité et des systèmes d'information (ANSSI) avec le soutien du Club EBIOS ». Sa version en vigueur est la v1.5, publiée en septembre 2024.

Sa mécanique : cinq ateliers qui vont du plus stratégique (les missions, ce qu'on craint) au plus technique (les modes opératoires d'attaque), puis remontent vers la décision (le traitement). Son articulation avec les normes est explicite : le guide se déclare compatible avec les référentiels en vigueur, « en particulier les normes de la série ISO/IEC 27000 et notamment 27005:2022 avec laquelle la méthode EBIOS RM est conforme ». Sa limite, enfin : c'est une méthode d'appréciation et de traitement, pas une garantie de sécurité ni un catalogue de mesures ; elle organise le jugement collectif, elle ne le remplace pas, et la qualité de ses résultats vaut ce que valent les participants réunis et les informations qu'on leur donne.

Autrement dit : ISO 27001 exige, ISO 27005 préconise, EBIOS RM outille. Les trois se complètent au lieu de se concurrencer, et un RSSI de groupe les mobilise généralement ensemble : la norme d'exigences pour le système de management, la préconisation pour le processus, la méthode pour les ateliers concrets.

✓ Deux approches qui se partagent le travail

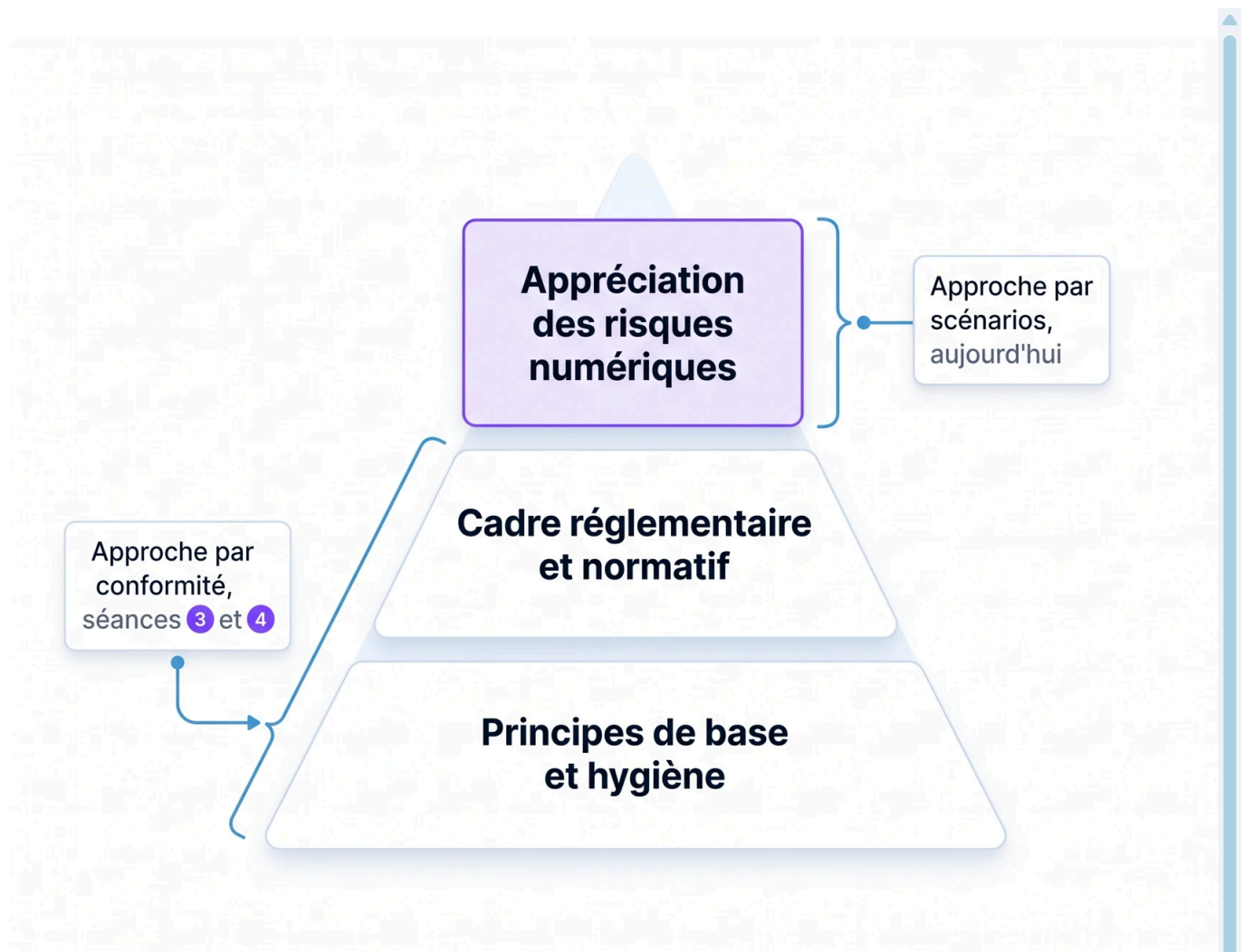
La méthode repose sur une idée simple et puissante, symbolisée par sa pyramide du management du risque numérique. Le guide la formule ainsi : l'ensemble des risques est appréhendé par la combinaison « d'une approche par conformité pour déterminer le socle de sécurité pour les risques les plus communs, y compris ceux liés à des événements accidentels et environnementaux ; et d'une approche par scénarios pour identifier les risques avancés d'origine intentionnelle, et notamment les attaques particulièrement ciblées ou sophistiquées ».

Deux incidents réels illustrent pourquoi ce partage existe. En 2017, la campagne WannaCry a produit, selon les premiers signalements recensés par la CISA (l'agence américaine de cybersécurité) américaine, des dizaines de milliers d'infections dans plus de 150 pays : un rançongiciel auto-propagé, non ciblé, qui frappait toute machine non corrigée. Contre ce type de menace, construire des scénarios d'attaque personnalisés n'apporte rien : ce qui protège, c'est le socle, l'hygiène, les correctifs appliqués, c'est-à-dire la conformité à des référentiels connus. À

l'inverse, la compromission SolarWinds, découverte en décembre 2020, a distribué une mise à jour piégée du produit Orion à environ 18 000 clients publics et privés : une attaque préparée, patiente, passant par la chaîne d'approvisionnement logicielle. Aucune liste de bonnes pratiques ne suffit à raisonner ce cas ; il faut se mettre à place de l'attaquant, imaginer ses chemins, et c'est exactement ce que fait l'approche par scénarios.

	Approche par conformité	Approche par scénarios
Risques visés	Les plus communs, y compris accidentels et environnementaux	Avancés, intentionnels, ciblés ou sophistiqués
Question posée	Appliquons-nous les règles reconnues ?	Que ferait une source de risque motivée ?
Matériau	Référentiels, guides, réglementations, PSSI (politique de sécurité des systèmes d'information)	Sources de risque, chemins d'attaque, modes opératoires
Où dans la méthode	Atelier 1 : le socle de sécurité	Ateliers 2 à 4 : l'appréciation des risques
Menace type	Rançongiciel opportuniste façon WannaCry	Compromission préparée façon SolarWinds

La pyramide range ces deux approches en trois étages : les principes de base et l'hygiène en bas, le cadre réglementaire et normatif au milieu, l'appréciation des risques numériques au sommet. Les deux premiers étages relèvent de la conformité, le dernier des scénarios. La trajectoire du module suit exactement cette pyramide : les séances 3 et 4 ont travaillé les deux étages de conformité (choisir le référentiel, auditer l'écart), et le troisième se franchit aujourd'hui. C'est aussi pour cela que le glossaire du guide précise que l'appréciation des risques, « ensemble du processus d'identification, d'analyse et d'estimation des risques », correspond dans la démarche EBIOS RM aux ateliers 2, 3 et 4 : l'atelier 1, lui, est le prérequis de l'appréciation, celui qui pose le cadre et le socle, et l'atelier 5 en est l'aboutissement décisionnel.



✓ Cinq ateliers, deux cycles : la mécanique

Voici la méthode entière d'un seul regard. Les intitulés sont ceux du guide, à employer tels quels dans les livrables

Atelier	Intitulé exact	La question à laquelle il répond	Ce qui en sort
1	Cadrage et socle de sécurité	Sur quoi porte l'étude, et où en est notre conformité ?	Cadrage, missions, valeurs métier et biens supports, événements redoutés et gravité, socle et écarts
2	Sources de risque	Qui pourrait nous attaquer, et pour obtenir quoi ?	Couples source de risque / objectif visé retenus et cartographiés
3	Scénarios stratégiques	Par quels chemins, à travers notre écosystème ?	Scénarios stratégiques et chemins d'attaque, estimés en gravité
4	Scénarios opérationnels	Concrètement, sur quels biens supports, par quelles actions ?	Scénarios opérationnels estimés en vraisemblance
5	Traitement du risque	Que décide-t-on, et que reste-t-il après ?	Stratégie de traitement, plan de traitement, risques résiduels, cadre de suivi

Deux logiques traversent ce tableau et méritent d'être dites explicitement. La première est la mécanique de la mesure : la gravité naît en amont, portée par les événements redoutés de l'atelier 1 et transmise aux scénarios stratégiques de l'atelier 3 ; la vraisemblance naît en aval, estimée sur les scénarios opérationnels de l'atelier 4 ; et le niveau de risque, propre à chaque scénario de risque, combine les deux à l'atelier 5. Le guide le résume d'une note : « en général, chaque chemin d'attaque d'un scénario stratégique donne lieu à un scénario opérationnel. Un scénario de risque correspond à l'association d'un chemin d'attaque et de son scénario opérationnel. » Maîtriser les ateliers 3 et 4 n'est pas nécessaire aujourd'hui : la séance 6 les conduira sur l'écosystème du groupe, ses prestataires et sa chaîne d'approvisionnement, là où ils prennent tout leur sens.

La seconde logique est le temps. La méthode n'est pas un exercice qu'on fait une fois : « La démarche prévoit deux cycles, dont les durées sont définies lors du premier atelier : un cycle stratégique revisitant l'ensemble de l'étude et en particulier les scénarios stratégiques ; un cycle opérationnel revenant sur les scénarios opérationnels à la lumière des incidents de sécurité survenus, de l'apparition de nouvelles vulnérabilités et de l'évolution des modes opératoires. » Pour fixer les idées, le guide indique que pour une homologation de système d'information, « les durées sont de trois ans pour le cycle stratégique et d'un an pour le cycle opérationnel ». L'analyse de risque est donc un organisme vivant : le haut de l'édifice bouge lentement, le bas se réévalue au rythme de la menace.

La démarche EBIOS Risk Manager, telle que l'outil la présente



Ateliers et activités tels que nommés dans CISO Assistant v3.21, module EBIOS RM ; intitulés d'ateliers du guide ANSSI

Dernier trait de caractère, qui évite un contresens fréquent : la méthode se présente comme une boîte à outils adaptable, pas comme un rite complet obligatoire. Le guide propose une grille d'usages qui module les ateliers à conduire selon l'objectif : identifier uniquement son socle de sécurité peut se faire avec le seul atelier 1 ; une étude complète en vue d'une homologation les mobilise tous. Face à une organisation qui « fait de l'EBIOS » en remplissant mécaniquement cinq gabarits sans se demander ce que son étude vise, le constat s'impose : l'esprit de la méthode s'est perdu en route.

Les ateliers 1 et 2 chez MERIDIAN : le travail de l'après-midi

Retour au concret, car l'après-midi y est entièrement consacré. L'atelier 1 ouvre l'étude, et sa première étape est un acte de gouvernance plus que de technique : définir l'objectif de l'étude, identifier les participants et leurs rôles, poser le cadre temporel des deux cycles. Le guide insiste sur un point repris dans les critères du livrable : « il est indispensable d'identifier quelle est la personne responsable d'accepter les risques résiduels au terme de l'étude ». Chez MERIDIAN, la gouvernance de la séance 1 donne la réponse : la Direction Générale, qui fixe l'appétence, est la seule légitime pour accepter ce qui restera au-dessous d'elle. Le point du RSSI de ce matin a préparé exactement ce dont cette étape a besoin.

Vient ensuite le périmètre métier et technique : missions, valeurs métier, biens supports. Et c'est ici que la séance 2 paie sa promesse. Ces objets ne s'inventent pas en atelier : ils se REPRENENT de la cartographie, dans les mêmes termes. Le guide EBIOS le dit lui-même : pour lister les biens supports, « appuyez-vous sur la cartographie du système d'information de l'organisme », et sa note renvoie explicitement au guide de l'ANSSI « Cartographie du système d'information, guide d'élaboration en 5 étapes », celui-là même qui a été appliqué en séance 2. Une organisation sans cartographie doit improviser cette étape en séance de travail, avec les trous et les oublis que cela implique ; le RSSI Groupe, lui, arrive avec le matériel prêt. Le guide recommande d'ailleurs de rester frugal : «

5 à 10 valeurs métier constituent généralement une base suffisante pour orienter la suite de l'étude », et un à trois biens supports par valeur métier suffisent à ce stade. Le Top 5 d'actifs critiques de la séance 2 tombe exactement dans cette épure.

Suivent les événements redoutés et leur gravité, formulés valeur métier par valeur métier en parcourant les besoins DICT, puis le socle de sécurité : « liste des référentiels applicables, état d'application, identification et justification des écarts », selon les données de sortie de l'atelier. Là encore, le RSSI Groupe n'arrive pas les mains vides : le référentiel choisi en séance 3 et le rapport d'audit de la séance 4 SONT l'état d'application demandé. L'atelier 1 ne refait pas l'audit, il le consomme, et il en tire une décision que le guide formule sans détour : en cas d'écarts trop significatifs, renforcer le socle avant de poursuivre ; sinon, « poursuivre en considérant la non-conformité, les scénarios de risques viendront exploiter les éventuelles fragilités du socle de sécurité ».

L'atelier 2, enfin, change de camp : après avoir regardé ce qui compte pour le groupe, l'atelier regarde qui pourrait s'y intéresser. Sa question fondatrice, selon le guide : « qui ou quoi pourrait porter atteinte aux missions et valeurs métier identifiées dans l'atelier 1, et dans quels buts ? » On y recense les sources de risque et leurs objectifs visés ; on évalue la pertinence de chaque couple selon trois critères, la motivation, les ressources et l'activité, puis on retient les couples prioritaires : « 3 à 6 couples SR/OV (source de risque / objectif visé) constituent généralement une base suffisante pour élaborer des scénarios stratégiques ».

Et la boucle se referme élégamment : le guide recommande de confronter le point de vue du défenseur, les événements redoutés, à celui de l'attaquant, les couples SR/OV, pour vérifier qu'aucun événement redouté grave ne reste sans source plausible, et réciproquement. Chez MERIDIAN, les candidats se devinent déjà : la donnée de santé attire l'extorsion, la chaîne logistique craint l'interruption, une plateforme de services aux citoyens attire ceux qui cherchent une caisse de résonance. L'après-midi tranchera avec la rigueur de la grille, pas avec des intuitions.

✓ Ce que la méthode ne promet pas

Ce cours se ferme sur les limites, parce qu'un expert se reconnaît à ce qu'il sait ne pas demander à ses outils. L'appréciation du risque ne prédit rien : elle hiérarchise des plausibilités pour éclairer des décisions, et un risque coté faible peut se réaliser demain. Elle ne remplace pas l'appétence : la grille dit où se situe chaque risque, l'appétence dit où passe la ligne de l'acceptable, et cette ligne est une décision de direction, pas un résultat de calcul. Elle vaut enfin ce que vaut son matériau : une cartographie fausse produit une étude fausse avec la même assurance. Le CHU (centre hospitalier universitaire) de Rouen, frappé par un rançongiciel en 2019, a rappelé au secteur hospitalier français que le risque numérique se paie en brancards et en reports de soins, pas seulement en euros : au moment d'animer les ateliers cet après-midi, c'est cette réalité-là que les échelles de gravité doivent capturer, et c'est pour elle que la rigueur du vocabulaire n'est pas un luxe d'école.

Ce midi, le QCM vérifie le vocabulaire et la mécanique des ateliers 1 et 2. L'après-midi conduit ces deux ateliers sur MERIDIAN, saisit leurs résultats dans CISO Assistant, puis pose les échelles du groupe et assemble le premier livrable d'appréciation du risque. La cartographie a cessé d'être un exercice : elle devient une arme.